

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	Access to the internal folder was not limited to the sales team and the manager. Moreover, he was forgetful enough to show the sensitive content of the folder to another person
Review	NIST SP 800-53: AC-6 describes the control called principle of least privilege. How you should implement that and how you can enhance it's impact. Principle of least privilege means that any user account should have amount of access only to complete their task. It is important to implement this principle to maintain the privacy of data and it's security posture. You should grant the employee with the necessary access while he is working to accomplish intended objectives and revoke this access after that. Also keep activity logs of provisioned user accounts and regularly conduct security audits to reduce the risk of possible vulnerability.

Recommendation (s)	In this situation, the most useful control enhancements would be: 1. Restricting access to sensitive resources based on user role 2. Automatically revoke access to the mentioned sensitive information after certain period of time
Justification	If these control enhancements were implemented, the situation would rely on automated process, not on the memory of the employee and even unintentionally, he couldn't share the sensitive information with others.